FIELD GUIDE

# Zero Trust

Eight weeks from practitioner to lead. A shared core, then a track for where you work.

Public edition v2.8, 18 October 2026. By Ken Connell. Public sources only.

## How to use this guide

**Premise.** Zero Trust is learned fastest on real systems. If you already do Zero Trust work, that work is the classroom. If you don't yet, pick one system you know well and practice on it every week.

**Structure.** Weeks 1 to 4 are a core that everyone takes: the definition (NIST SP 800-207) and the shared maturity scale (the CISA Zero Trust Maturity Model). Weeks 5 to 8 are one track, picked by who sets your Zero Trust rules:

- **DoW track.** For Department of War (DoW) components and the programs that report to them.
- **Federal civilian track.** For federal civilian agencies and the teams that build and run their systems.
- **Private sector track.** For companies, and also state and local governments, universities and anyone else with no federal Zero Trust mandate.

Not sure which? The "Which track are you?" table below settles it.

**Time.** About 3 hours a week in the core, and 3 to 5 in your track. One hour on weekdays, or two longer blocks.

**What you will be able to do by the end of Week 8.**

- Explain Zero Trust, and the roadmap that governs your organization, in one breath, to any stakeholder, without notes.
- Take one capability, such as multi-factor authentication, and walk it across the frameworks that apply to you, out loud.
- Tell a security idea from a Zero Trust idea on sight, and say the Zero Trust version.

**Field notes.** Keep one text file, one line per session: Learned / Source / Where it bit us. The template is in Part 6. In three months it is your field manual, in your own words.

**Naming.** The Department's current title is Department of War (DoW), authorized by Executive Order 14347. Published document titles still say "DoD," so this guide uses DoW in prose and DoD in titles and citations.

## Which track are you?

| IF YOU ARE... | YOUR ZERO TRUST RULES COME FROM | YOUR TRACK |
|---|---|---|
| **A DoW component, or a program that reports to one** | The DoD Zero Trust Strategy and its activity list: Target Level by the end of FY27 | DoW |
| **A federal civilian agency, or a team building or running its systems** | EO 14028 and OMB M-22-09, organized by the CISA maturity model | Federal civilian |
| **A company, a state or local government, a university, or anyone else** | No federal Zero Trust mandate. You pick a target, unless a contract or regulator names one for you | Private sector |
| **A contractor handling controlled unclassified information (CUI) for DoW** | NIST SP 800-171 and the CMMC program set your security requirements. They are not Zero Trust frameworks | Private sector, plus the pointer in that track |

Everyone takes the core. It is the vocabulary every track borrows.

## Part 1. The core (Weeks 1 to 4)

Each card says what the document is, why it matters, what to read, what to skip, and the one sentence you should be able to say afterward.

### Core 1. NIST SP 800-207, Zero Trust Architecture (NIST, August 2020)

**What it is.** The foundational definition. The tenets of Zero Trust, the logical components (policy engine, policy administrator, policy enforcement point), deployment models, and the trust algorithm.

**Why it matters.** Everyone borrows its vocabulary: DoW, federal civilian and commercial Zero Trust documents all build on it. When someone says PDP or PEP in a meeting, this is the document most people learned the words from.

**Read.** Section 2 (tenets and the Zero Trust view of a network) and Section 3 (logical components, deployment variations, trust algorithm). About 19 pages. In Week 2, skim Section 4 (use cases) and Section 7 (migration).

**Skip for now.** Section 5 threats (skim later); the appendices.

**Be able to say.** Zero Trust means every access request is decided by a policy engine on identity, device posture and context, enforced at a PEP, with no trust implied by where the request comes from.

**Time.** 6 hours. Weeks 1 and 2.

### Core 2. CISA Zero Trust Maturity Model v2.0 (CISA, April 2023)

**What it is.** Five pillars (Identity, Devices, Networks, Applications and Workloads, Data), three cross-cutting capabilities (Visibility and Analytics, Automation and Orchestration, Governance), and four stages (Traditional, Initial, Advanced, Optimal), with a stage description for every function.

**Why it matters.** It is the closest thing to a shared maturity scale. CISA wrote it for federal civilian agencies, and OMB M-22-09 organizes its goals by it. It is public, so private-sector teams can borrow its stages as a target. Some DoW programs report through it too.

**Read.** The introduction, the stage definitions, and the five pillar chapters in Week 3. The cross-cutting capabilities in Week 4. Read for vocabulary and structure; you do not need the functions memorized.

**Skip for now.** Nothing. It is short enough to read whole.

**Be able to say.** Five pillars, three cross-cutting capabilities, four stages, and which pillar and stage one of your own controls sits at, and why.

**Time.** 6 hours. Weeks 3 and 4.

## Core weekly plan

| WEEK | READ | APPLY ON THE JOB | SELF-CHECK |
|---|---|---|---|
| **Week 1** | NIST 800-207, Sections 2 and 3. | List who decides access in your environment today, and where each decision is enforced. That is your first PDP and PEP map, even if nobody calls it that. | Name the seven tenets. Draw the PE, PA, PEP triangle and say what each does. |
| **Week 2** | NIST 800-207: skim Section 4 (use cases) and Section 7 (migration). Pick your track using the table above. | Match your environment to the closest Section 4 use case. Then write the first line of your one-breath answer (Fluency 1): what Zero Trust is, in your own words. | Say why "inside the network" earns no trust. Name your track and the document that sets your rules. |
| **Week 3** | CISA ZTMM 2.0: introduction, stages, the five pillar chapters. | Take one real control in your environment and say which pillar and stage it sits at, and why. Do the core capability walk (Fluency 2) for multi-factor authentication. | Five pillars, four stages. Place MFA, DLP and microsegmentation in the right pillar without looking. |
| **Week 4** | CISA ZTMM 2.0: the three cross-cutting capabilities. | Run Fluency 3 on five security ideas you hear this week, and say the Zero Trust version of each. | Five plus three, four stages. Say what Governance adds that no single pillar covers. |

# Part 2. The tracks (Weeks 5 to 8)

Pick one. Each track has its canon, a four-week plan, and what to skip.

## DoW track

For DoW components, and the programs and teams that report to them.

### D1. DoD Zero Trust Strategy (DoD CIO, October 2022)

**What it is.** The Department's mandate: the vision, four strategic goals, the seven pillars, Target Level and Advanced Level, and the FY27 deadline for Target.

**Why it matters.** It sets the destination for every DoW component: seven pillars, and a Target Level due by the end of FY27. Every other DoW Zero Trust document points back to it.

**Read.** Executive summary and the strategy sections on goals, pillars and the Target and Advanced split. About 20 pages.

**Skip for now.** Governance and organizational sections, including the material on the DoD ZT Portfolio Management Office.

**Be able to say.** DoW requires Target Level Zero Trust across every component by the end of FY27, and Target is 91 of the 152 activities.

**Time.** 2 hours. Week 5.

### D2. DoD Zero Trust Capabilities and Activities (DoD CIO ZT PfMO, as of 18 March 2025)

**What it is.** The yardstick. Seven pillars, 45 capabilities, 152 activities, each with outcomes, a level (Target or Advanced), and an end state.

**Get the right file.** The current activity list is the hyphenated `ZT-CapabilitiesActivities.pdf`. An older file at the similar, unhyphenated address served an earlier edition (6 January 2023); that link is now dead. Check the cover date before you trust a copy.

**Why it matters.** It is the full catalog behind the Strategy: 45 capabilities and 152 activities, each with published outcomes. Learn its numbering, because every other DoW document uses it.

**Read.** One or two pillars a week, in this order: User, Device; Network; Application and Workload, Data; Automation and Orchestration, Visibility and Analytics.

**Skip for now.** Nothing. But do not try to memorize outcomes. Memorize the capability names and the Target count per pillar; the outcomes are what your notes are for.

**Be able to say.** The capabilities in each pillar from memory, and the Target count per pillar (table in Part 5).

**Time.** 6 hours across Weeks 5 to 8.

### D3. NSA Zero Trust Implementation Guidelines: Primer, Discovery Phase, Phase One, Phase Two (NSA Cybersecurity Technical Reports, January 2026)

**What it is.** NSA's sequencing of the DoD Target activities into phases with dependencies: Discovery (14 activities), Phase One (36), Phase Two (41). Phases Three and Four will cover the Advanced activities; NSA says they "may be developed at a later date." Status checked 30 September 2026.

**Why it matters.** It is NSA's practical companion to the activity list, grouped into phases you can read in order.

**Read.** Primer, Discovery Phase and Phase One in full. Phase Two: the activity roster and the dependency notes.

**Be able to say.** Discovery is the inventories and analyses (users, devices, applications, data, flows, policies); Phase One is the foundational controls on top of them; Phase Two builds out and integrates. Fourteen, thirty-six, forty-one.

**Time.** 4 hours. Week 6.

### D4. DoD Zero Trust Reference Architecture v2.0 (DISA and NSA for DoD CIO, July 2022)

**What it is.** The architecture behind the strategy: principles, pillar target states, capability taxonomy, and the operational and system views. Long and dense.

**Why it matters.** It is where "what good looks like" is written for each capability. When a system owner asks what Target actually means for their system, the answer is here.

**Read.** Section 1 (purpose and strategic goals), the principles, and the User, Device and Network pillar descriptions in Section 2. Glance at the capability taxonomy so you recognize it as the parent of the 45.

**Skip for now.** The operational and system views beyond a glance; the appendices.

**Be able to say.** One sentence per pillar describing the target state. For example: Network at Target means data flows are mapped, the enterprise is macro-segmented, and critical workloads are micro-segmented on identity, with policy applied programmatically.

**Time.** 4 hours. Week 7.

### DoW TRACK WEEKLY PLAN

| WEEK | READ | APPLY ON THE JOB | SELF-CHECK |
|---|---|---|---|
| **Week 5** | DoD ZT Strategy. Capabilities and Activities: overview pages, Pillar 1 User and Pillar 2 Device. | Explain each of the nine User capabilities in one sentence, in your own words. Then pick the one you find hardest and say why. | The four strategic goals. Nine User and seven Device capabilities by name. Why FY27. |
| **Week 6** | NSA ZIG Primer, Discovery Phase, Phase One; skim Phase Two. Capabilities and Activities: Pillar 5 Network. | Pick three Discovery activities and explain what each one inventories. Explain what Comply to Connect adds that network access control alone does not. | Fourteen, thirty-six, forty-one. Name five Discovery activities and what each inventories. C2C in one sentence. |
| **Week 7** | DoD ZT RA 2.0: Section 1, principles, and the User, Device and Network pillar descriptions. Capabilities and Activities: Pillar 3 Application and Workload, Pillar 4 Data. | Pick one Reference Architecture principle and find where it shows up in the User and Device pillars. Then explain why cataloging critical data (4.1.1) and defining granular access rules (5.1.1) are Discovery activities. | One sentence per pillar on what Target looks like. Five Application and seven Data capabilities. |
| **Week 8** | Capabilities and Activities: Pillar 6 Automation and Orchestration, Pillar 7 Visibility and Analytics. Capstone. | Capstone: a ten-minute teach-back. The roadmap in one breath, one capability walk, one Zero Trust explanation. Then write the field-notes summary for the eight weeks. | All three fluencies, no notes. |

> **Not yet, on this track.** Vendor whitepapers and anything titled "ZT for cloud-native" until after Week 8. OMB M-22-09 is addressed to every executive department, the Department included, but DoW's program runs on the DoD Strategy and activity list; read M-22-09 later, to see where the two line up.

## Federal civilian track

For federal civilian agencies, and the teams that build and run their systems.

### F1. Executive Order 14028, Improving the Nation's Cybersecurity (White House, May 2021), Section 3

**What it is.** The root mandate. Section 3 says the federal government must advance toward Zero Trust Architecture, and gave each agency head 60 days to develop a plan to implement it.

**Why it matters.** Every federal civilian Zero Trust requirement traces back to it. Later executive orders changed other parts of the cybersecurity agenda; Section 3's Zero Trust direction still stands, as checked 30 September 2026.

**Read.** Section 3, Modernizing Federal Government Cybersecurity. About 3 pages.

**Be able to say.** EO 14028 directed the move to Zero Trust; M-22-09 set the targets.

**Time.** 1 hour. Week 5.

### F2. OMB Memorandum M-22-09, Moving the U.S. Government Toward Zero Trust Cybersecurity Principles (OMB, January 2022)

**What it is.** The federal Zero Trust strategy. It sets specific goals for every executive department and agency, due by the end of fiscal year 2024, organized by the five pillars of the CISA maturity model.

**Why it matters.** It is the most concrete statement of what federal civilian Zero Trust means: enterprise identities with phishing-resistant MFA, a complete device inventory with detection and response, encrypted DNS and HTTP traffic with a plan to break down perimeters, applications treated as internet-connected and tested, and data protection built on categorization.

**Read.** All of it. Read the five pillar goals twice.

**Watch.** Its deadline, the end of FY2024, has passed. No rescission was found as of 30 September 2026. Check OMB's memoranda page and the current FISMA guidance for what agencies report now.

**Be able to say.** The M-22-09 goal for each of the five pillars, in one sentence each.

**Time.** 3 hours. Week 5.

### F3. OMB Memorandum M-26-14, Ensuring Effective and Efficient Agency Logging and Network Visibility to Defend Against Evolving Cyber Threats (OMB, May 2026)

**What it is.** The current federal logging memo. It rescinded the earlier logging memo, M-21-31, and aligns its logging requirements with the CISA maturity model.

**Why it matters.** Visibility is a cross-cutting capability in the CISA model, and logging is where it becomes a requirement.

**Read.** The requirements sections, and how they map to the maturity model.

**Be able to say.** Which memo sets federal logging requirements today, and how it connects to the maturity model.

**Time.** 2 hours. Week 6.

### F4. CISA, Microsegmentation in Zero Trust, Part One: Introduction and Planning (CISA, July 2025)

**What it is.** CISA's guide to moving from perimeter security to microsegmentation, part of its "Journey to Zero Trust" series. It lays out a four-phase approach and the planning considerations that go with it. A technical implementation part is planned.

**Why it matters.** Networks is the pillar where M-22-09 asked agencies to start breaking down perimeters. This is the how.

**Read.** All of it.

**Be able to say.** Why microsegmentation limits lateral movement, and the first thing you would plan before segmenting anything.

**Time.** 3 hours. Week 7.

### F5. Federal Zero Trust Data Security Guide (Federal CISO Council and CDO Council, October 2024, revised May 2025)

**What it is.** Practical guidance on defining, securing and managing data through its lifecycle, focused on the Data pillar of the CISA maturity model. The May 2025 revision added a chapter.

**Why it matters.** Data is often the pillar programs reach last, and it depends on the categorization M-22-09 asked for.

**Read.** The chapters on defining and securing data.

**Be able to say.** Why data categorization comes before data protection tools.

**Time.** 3 hours. Week 8.

### FEDERAL CIVILIAN TRACK WEEKLY PLAN

| WEEK | READ | APPLY ON THE JOB | SELF-CHECK |
|---|---|---|---|
| **Week 5** | EO 14028 Section 3. OMB M-22-09. | Take the five M-22-09 pillar goals and say, in plain language, what each would change for one system you know. | The five pillar goals, one sentence each. Why the EO and the memo are separate documents. |
| **Week 6** | OMB M-26-14. Re-read the CISA model's Visibility and Analytics capability. | Trace where one system's logs go today. Name what the logging memo would ask you to add. | Which memo governs federal logging now, and what it replaced. |
| **Week 7** | CISA Microsegmentation Part One. | Sketch one system's data flows and name the first segment you would draw, and why. | The four phases, in order. Macro versus micro segmentation. |
| **Week 8** | Federal Zero Trust Data Security Guide. Capstone. | Capstone: a ten-minute teach-back. Your roadmap in one breath, one capability walk, one Zero Trust explanation. Then write the field-notes summary for the eight weeks. | All three fluencies, no notes. |

> **Not yet, on this track.** The DoD activity list and the NSA implementation guidelines. They are well built, and worth reading after Week 8, but their pillar names and counts differ from the CISA model's and will muddy your terms while you are learning them.

## Private sector track

For companies, and for state and local governments, universities and anyone else with no federal Zero Trust mandate.

**Start here.** No federal Zero Trust mandate binds you, unless a contract or regulator names a framework. In that case, start from the framework they named. Otherwise the pattern is: use the Cybersecurity Framework to say what good looks like, SP 800-207 to define Zero Trust, the CISA maturity model to set a target, and SP 1800-35 to see how others built it.

### P1. The NIST Cybersecurity Framework (CSF) 2.0 (NIST, February 2024)

**What it is.** A taxonomy of cybersecurity outcomes for any organization, of any size or sector. Six functions: Govern, Identify, Protect, Detect, Respond, Recover.

**Why it matters.** It is the language boards and auditors already use. Zero Trust work lands mostly in Protect (identity management, authentication and access control) and Detect, and it is steered by Govern.

**Read.** The overview of the six functions, and the Govern and Protect sections of the core.

**Be able to say.** The six functions, and which of them a Zero Trust program mostly serves.

**Time.** 3 hours. Week 5.

### P2. NIST SP 1800-35, Implementing a Zero Trust Architecture (NIST National Cybersecurity Center of Excellence, June 2025)

**What it is.** NIST's practice guide: 19 example Zero Trust implementations built with 24 collaborators, with lessons learned and mappings to common security standards.

**Why it matters.** It turns the SP 800-207 model into working builds. It is the closest thing to seeing how other organizations actually did it.

**Read.** The high-level document, then the example build closest to your own environment.

**Skip for now.** The builds unlike your environment.

**Be able to say.** How one example build places the PDP and the PEPs, and what it would take to do the same in your environment.

**Time.** 4 hours. Week 6.

### P3. CISA Zero Trust Maturity Model v2.0, as your target (CISA, April 2023)

**What it is.** You read it in the core. On this track you use it as a target: pick a stage per pillar and write it down.

**Why it matters.** Without a mandate, you need a target you chose on purpose. Borrowing a public one makes it easy to explain.

**Read.** Re-read the stage tables for the pillars that matter most to your organization.

**Be able to say.** Your target stage per pillar, and why you chose it.

**Time.** 2 hours. Week 7.

### P4. CISA, Microsegmentation in Zero Trust, Part One: Introduction and Planning (CISA, July 2025)

**What it is.** CISA's guide to moving from perimeter security to microsegmentation. It names federal civilian agencies but says any organization can apply it.

**Why it matters.** Segmentation is often where private-sector programs spend their first real Zero Trust money.

**Read.** All of it.

**Be able to say.** Why microsegmentation limits lateral movement, and the first thing you would plan before segmenting anything.

**Time.** 3 hours. Week 7 or 8.

> **Handling CUI for a DoW contract?** Your security requirements come from NIST SP 800-171 and the DoW CMMC program, not from a Zero Trust framework. Zero Trust can help you meet them, but it does not replace them. Read SP 800-171 alongside this track.

**PRIVATE SECTOR TRACK WEEKLY PLAN**

| WEEK | READ | APPLY ON THE JOB | SELF-CHECK |
|---|---|---|---|
| **Week 5** | NIST CSF 2.0: the six functions, Govern and Protect. | Take three things your organization already does for security and name the CSF function each serves. | The six functions. Where identity management, authentication and access control sit. |
| **Week 6** | NIST SP 1800-35: the high-level document and one example build. | Draw your environment's version of that build: where would your PDP and PEPs sit? | What the NCCoE builds show that SP 800-207 alone does not. |
| **Week 7** | CISA ZTMM 2.0 stage tables, as a target. CISA Microsegmentation Part One. | Write your target stage for each of the five pillars, with one line of why. | Your five targets from memory. |
| **Week 8** | Finish the microsegmentation guide. Capstone. | Capstone: a ten-minute teach-back. Zero Trust in one breath, one capability walk, one Zero Trust explanation. Then write the field-notes summary for the eight weeks. | All three fluencies, no notes. |

> **Not yet, on this track.** The DoD activity list and the federal memos. They are written for organizations bound by them, and their deadlines and counts do not apply to you. Vendor maturity models can wait too: learn the public ones first, so you can tell what a vendor's version adds.

## Part 3. The eight weeks at a glance

| WEEK | EVERYONE | DoW | FEDERAL CIVILIAN | PRIVATE SECTOR |
|---|---|---|---|---|
| **1** | NIST 800-207, Sections 2 and 3 | | | |
| **2** | NIST 800-207, skim Sections 4 and 7; pick your track | | | |
| **3** | CISA ZTMM: stages and five pillars | | | |
| **4** | CISA ZTMM: cross-cutting capabilities | | | |
| **5** | | Strategy; User and Device | EO 14028; M-22-09 | CSF 2.0 |
| **6** | | NSA ZIGs; Network | M-26-14 | SP 1800-35 |
| **7** | | Reference Architecture; Application and Data | Microsegmentation Part One | ZTMM as target; Microsegmentation |
| **8** | | Automation and Visibility; capstone | Data Security Guide; capstone | Microsegmentation; capstone |

If a week slips, do not double up. Push the plan a week and keep the order; the order is the point.

# Part 4. Three fluencies, with drills

## Fluency 1. Zero Trust in one breath

Say it until it comes out at conversational speed. Then say it to someone. Everyone learns the core version; add your track's version.

> **Core.** Zero Trust means no user, device or network location is trusted by default. Every request for a resource is decided by policy, on identity, device posture and context, and enforced and logged at the point of access. NIST SP 800-207 defines it; the CISA maturity model measures it in five pillars, three cross-cutting capabilities and four stages.

> **DoW.** DoW's Zero Trust roadmap has seven pillars: User, Device, Application and Workload, Data, Network and Environment, Automation and Orchestration, and Visibility and Analytics. Under them sit 45 capabilities and 152 activities. Ninety-one are Target Level, due across the Department by the end of FY27; sixty-one are Advanced and come after. Each activity has published outcomes, and meeting every one is the Target bar.

> **Federal civilian.** Executive Order 14028 moved the federal government toward Zero Trust in 2021. OMB M-22-09 set goals for every agency across the five CISA pillars: enterprise identities with phishing-resistant MFA, a full device inventory, encrypted traffic and smaller perimeters, applications treated as internet-connected, and data protection built on categorization. CISA's maturity model measures progress, and newer memos, like the 2026 logging memo, build on it.

> **Private sector.** No federal Zero Trust mandate binds us, so we chose our own target. We use the Cybersecurity Framework to describe what good looks like, NIST SP 800-207 to define Zero Trust, the CISA maturity model to set a target stage per pillar, and NIST's example builds in SP 1800-35 to see how others got there.

**Drill.** Time yourself. Under 45 seconds, with no filler words, and you are there. If a number wobbles, it is in Part 5.

## Fluency 2. The capability walk

Take one capability and cross every framework that applies to you. A worked example: multi-factor authentication. Everyone does the core rows; then add your track's row.

| FRAMEWORK | 1 MULTI-FACTOR AUTHENTICATION |
|---|---|
| **NIST SP 800-207 (core)** | Authentication is part of every access decision: the policy engine weighs identity and context, and the PEP enforces the result per session. |
| **CISA ZTMM (core)** | Identity pillar, Authentication function. In broad strokes: Traditional is passwords or MFA on some systems; Advanced is phishing-resistant MFA broadly; Optimal is continuous validation with risk analysis. |

| FRAMEWORK | 1 MULTI-FACTOR AUTHENTICATION |
|---|---|
| **DoW track** | Capability 1.3 MFA, User pillar. Target activity 1.3.1 Organizational MFA/IdP: an enterprise identity provider with MFA for critical applications and services, using DoD PKI and approved alternatives by resource risk level. NSA ZIG: Phase One. NSA advises completing Discovery activity 1.1.1 (inventory users) first, because you cannot enforce MFA against identities you have not enumerated. |
| **Federal civilian track** | M-22-09's Identity goal: agency staff use enterprise-managed identities, protected by phishing-resistant MFA. |
| **Private sector track** | CSF 2.0, Protect function: identity management, authentication and access control. SP 1800-35's example builds show how an enterprise identity provider feeds the access decision. |
| **Where it bites (everyone)** | Legacy applications that manage their own accounts. They sit outside the enterprise identity provider, so MFA never reaches them. An honest identity inventory should expose every one. |

**Practice on:** device compliance before access; data flow mapping; data loss prevention; the policy decision point; log collection and correlation. Do one per week from Week 3. Write each walk in your field notes; the writing is the drill.

## Fluency 3. Security idea or Zero Trust idea?

**The test.** A Zero Trust idea is about a per-request access decision, made on identity, device posture and context, enforced and logged, or about the inventory, tag or policy that feeds one. A security idea is about whether a control exists or a practice is followed. Both matter. Only the first is Zero Trust.

| SECURITY IDEA | THE ZERO TRUST VERSION | CISA PILLAR OR CAPABILITY |
|---|---|---|
| **Anti-virus is installed on endpoints.** | Device compliance, including endpoint detection and protection status, is checked before each access decision, and non-compliant access is denied by default. | Devices |
| **There is a network access control solution.** | Devices are authenticated and posture-checked at connection, with non-compliant devices quarantined, across every part of the environment. | Devices, Networks |
| **Data is classified.** | Data objects are tagged to one standard, so that access decisions, data loss prevention and rights management consume the tags. | Data |
| **MFA is required for applications.** | All applications authenticate through the enterprise identity provider with MFA matched to resource risk, and you know which applications still hold their own accounts. | Identity |
| **The network is segmented.** | Data flows are mapped, enclaves are macro-segmented, and critical workloads are micro-segmented on identity, with policy changes applied programmatically. | Networks |
| **A SIEM is in place.** | Logs from all sources are parsed to a standard schema, with baseline alerting, asset correlation, and user and device baselines feeding it. | Visibility and Analytics, cross-cutting |
| **The AI assistant has guardrails.** | Every action the agent takes is authorized outside the model, against the scope the user delegated, and logged by the enforcement point rather than by the agent. | Identity, Applications and Workloads |

**Drill.** Take any security idea you hear this week and say its Zero Trust version out loud. If you can't, find its pillar in the CISA model and try again.

# Part 5. Numbers and vocabulary to own cold

Each track has a one-page Quick Reference with the same content. This is the version with room to annotate.

## Core numbers

- **NIST SP 800-207:** seven tenets; three core components (policy engine, policy administrator, policy enforcement point).
- **CISA ZTMM 2.0:** five pillars, three cross-cutting capabilities, four stages (Traditional, Initial, Advanced, Optimal).

## DoW track numbers

Counts as of the 18 March 2025 DoD Capabilities and Activities list, checked 30 September 2026.

| PILLAR | CAPABILITIES | TARGET | ADVANCED | CAPABILITY NAMES |
|---|---|---|---|---|
| **1 User** | 9 | 13 | 15 | 1.1 User Inventory; 1.2 Conditional User Access; 1.3 MFA; 1.4 Privileged Access Management; 1.5 Identity Federation & User Credentialing; 1.6 Behavioral, Contextual ID and Biometrics; 1.7 Least Privileged Access; 1.8 Continuous Authentication; 1.9 Integrated ICAM Platform |
| **2 Device** | 7 | 14 | 10 | 2.1 Device Inventory; 2.2 Device Detection and Compliance; 2.3 Device Authorization w/ Real Time Inspection; 2.4 Remote Access; 2.5 Automated Asset, Vulnerability and Patch Mgmt; 2.6 UEM & MDM; 2.7 EDR & XDR |
| **3 Application & Workload** | 5 | 12 | 6 | 3.1 Application Inventory; 3.2 Secure Software Development & Integration; 3.3 Software Risk Management; 3.4 Resource Authorization & Integration; 3.5 Continuous Monitoring and Ongoing Authorizations |
| **4 Data** | 7 | 17 | 14 | 4.1 Data Catalog Risk Alignment; 4.2 Enterprise Data Governance; 4.3 Data Labeling and Tagging; 4.4 Data Monitoring and Sensing; 4.5 Data Encryption & Rights Management; 4.6 DLP; 4.7 Data Access Control |
| **5 Network & Environment** | 4 | 10 | 3 | 5.1 Data Flow Mapping; 5.2 Software Defined Networking; 5.3 Macro Segmentation; 5.4 Micro Segmentation |
| **6 Automation & Orchestration** | 7 | 13 | 7 | 6.1 PDP & Policy Orchestration; 6.2 Critical Process Automation; 6.3 Machine Learning; 6.4 Artificial Intelligence; 6.5 SOAR; 6.6 API Standardization; 6.7 SOC & Incident Response |
| **7 Visibility & Analytics** | 6 | 12 | 6 | 7.1 Log All Traffic; 7.2 SIEM; 7.3 Common Security and Risk Analytics; 7.4 UEBA; 7.5 Threat Intelligence Integration; 7.6 Automated Dynamic Policies |
| **Total** | **45** | **91** | **61** | **152 activities** |

Three capabilities have no Target activities: 3.5 Continuous Monitoring and Ongoing Authorizations, 6.4 Artificial Intelligence, and 7.6 Automated Dynamic Policies are Advanced only. So the 91 Target activities span 42 of the 45 capabilities, the same count NSA's ZIG Primer gives.

DoD TO CISA MAP

| DoD PILLAR | CISA ZTMM 2.0 |
|---|---|
| **1 User** | Identity |
| **2 Device** | Devices |
| **3 Application & Workload** | Applications & Workloads |
| **4 Data** | Data |
| **5 Network & Environment** | Networks |
| **6 Automation & Orchestration** | Automation & Orchestration (cross-cutting) |
| **7 Visibility & Analytics** | Visibility & Analytics (cross-cutting) |
| **Governance-heavy capabilities (1.7, 2.2, 3.5, 4.1, 4.2, 6.1)** | Governance (cross-cutting), in addition to their pillar |

The governance-heavy row is my own read, not an official mapping: these are the capabilities whose outcomes depend most on policy and oversight rather than technology.

## Federal civilian track numbers

| CISA PILLAR | M-22-09 GOAL, IN SHORT |
|---|---|
| **Identity** | Enterprise-managed identities; phishing-resistant MFA |
| **Devices** | A complete inventory of every device; the ability to prevent, detect and respond to incidents on them |
| **Networks** | Encrypt DNS and HTTP traffic; start breaking perimeters into isolated environments |
| **Applications and Workloads** | Treat every application as internet-connected; test rigorously; welcome external vulnerability reports |
| **Data** | A shared path to protections built on thorough data categorization |

M-22-09's goals were due by the end of FY2024 (30 September 2024).

## Private sector track numbers

- **CSF 2.0:** six functions: Govern, Identify, Protect, Detect, Respond, Recover.
- **SP 1800-35:** 19 example implementations, 24 collaborators.
- **CISA ZTMM 2.0:** your target, one stage per pillar, chosen on purpose.

## Terms

| TERM | MEANING |
|---|---|
| **PE / PA / PEP** | Policy engine decides, policy administrator issues, policy enforcement point allows or blocks each access (NIST SP 800-207). PDP = PE + PA. |
| **PIP** | Policy information point: the sources a decision draws on (identity, device posture, threat intelligence, data tags). |
| **IdP / ICAM** | Identity provider; Identity, Credential and Access Management, the enterprise program identity rides on. |

| TERM | MEANING |
|---|---|
| **Phishing-resistant MFA** | MFA that a fake login page cannot capture and replay, such as FIDO2 security keys or PKI smart cards. |
| **ABAC / RBAC** | Attribute-based versus role-based access control. Zero Trust wants attributes driving decisions. |
| **JIT / JEA** | Just-in-time and just-enough administration: privilege granted for the task and the window, not standing. |
| **UEM / MDM** | Unified endpoint management and mobile device management: the compliance and inventory engine for devices. |
| **EDR / XDR** | Endpoint (and extended) detection and response; feeds device compliance and the SIEM. |
| **SDN** | Software defined networking: the control plane separated from the data plane, so segmentation is programmable. |
| **Macro / micro segmentation** | Macro: between enclaves and sites. Micro: per application or workload, identity-aware. |
| **DAAS** | Data, applications, assets, services: the things a PEP protects. |
| **DLP / DRM** | Data loss prevention and digital rights management: enforcement points that consume data tags. |
| **SIEM / SOAR / UEBA** | Log correlation and alerting; automated response playbooks; user and entity behavior baselines. |
| **FCEB** | Federal civilian executive branch: the agencies M-22-09 and CISA's guidance mostly address. |
| **CUI** | Controlled unclassified information: sensitive government information that contractors must protect under NIST SP 800-171. |
| **C2C (DoW)** | Comply to Connect: a device is identified, posture-checked and authorized before it gets network access; a non-compliant device is quarantined. |
| **Target / Advanced (DoW)** | DoD activity levels: 91 Target due by the end of FY27, 61 Advanced after. The Target bar is every published Target outcome met. |
| **Discovery / Phase One / Phase Two (DoW)** | NSA ZIG sequencing of the Target activities: 14 / 36 / 41. |

## Dates

| WHEN | WHAT | TRACK |
|---|---|---|
| **Aug 2020** | NIST SP 800-207, Zero Trust Architecture | Core |
| **May 2021** | EO 14028, Improving the Nation's Cybersecurity | Federal civilian |
| **Sep 2021** | CISA Zero Trust Maturity Model v1.0 draft released for public comment | Core |
| **Jan 2022** | OMB M-22-09, the federal Zero Trust strategy | Federal civilian |
| **Jul 2022** | DoD Zero Trust Reference Architecture v2.0 | DoW |
| **Oct 2022** | DoD Zero Trust Strategy (Target Level by the end of FY27) | DoW |
| **Apr 2023** | CISA Zero Trust Maturity Model v2.0 | Core |

| WHEN | WHAT | TRACK |
|---|---|---|
| **Sep 2023** | NIST SP 800-207A, Zero Trust for cloud-native applications | Core |
| **Feb 2024** | NIST Cybersecurity Framework 2.0 | Private sector |
| **30 Sep 2024** | End of FY2024: the M-22-09 deadline | Federal civilian |
| **Oct 2024** | Federal Zero Trust Data Security Guide (revised May 2025) | Federal civilian |
| **18 Mar 2025** | DoD ZT Capabilities and Activities, current version | DoW |
| **Jun 2025** | NIST SP 1800-35, Implementing a Zero Trust Architecture | Private sector |
| **Jul 2025** | CISA Microsegmentation in Zero Trust, Part One | Federal civilian, Private sector |
| **Sep 2025** | EO 14347 authorizes the Department of War (DoW) title | DoW |
| **14 Jan 2026** | NSA ZIG Primer and Discovery Phase | DoW |
| **30 Jan 2026** | NSA ZIG Phase One and Phase Two | DoW |
| **May 2026** | OMB M-26-14, federal logging and network visibility | Federal civilian |
| **Sep 2026** | CoSAI, Zero Trust for AI Systems v1.0 | Core |
| **30 Sep 2027** | End of FY27: the DoW Target Level deadline | DoW |

## Part 6. Field notes

One plain text file. Keep it public-safe: no organization names, people, findings or internal details. Those belong in your organization's own systems, not in personal study files.

**The format:** one line per session or reading.

```
2026-01-12 | Learned: a "policy decision point" is two NIST components, the policy engine and the policy administrator. | Source: NIST SP 800-207, Section 3. | Where it bit us: two teams arguing over which box owned a decision.
2026-01-19 | Learned: check the edition date before quoting a count; an older copy may carry an old number. | Source: the document's cover page. | Where it bit us: a talking point built on an outdated count.
2026-01-26 | Learned: | Source: | Where it bit us:
```

**Rules.**

- One line, no essays.
- "Learned" is a fact or a distinction, not a feeling.
- "Where it bit us" can be blank. When it is not blank, that line is the valuable one.
- Reread the file at the end of each week of the plan.

# Part 7. After Week 8

## Everyone

- **NIST SP 800-207A (September 2023).** Zero Trust access control for cloud-native applications, once cloud environments come into scope.
- **Zero Trust for AI Systems (Coalition for Secure AI, September 2026).** How the same ideas apply when an AI agent acts for a user: the model sits inside its own threat boundary and is never trusted to make authorization decisions, every tool call is authorized outside the model against the user's delegated scope, and the paper gives a three-step maturity path for getting there. For the red, blue and purple team view, see the Agentic SecOps playbook.
- **Zero Trust in the Age of AI (my companion notebook).** A NotebookLM notebook built on this guide's sources, the 2025 to 2026 guidance on AI agents and recorded talks, including transcripts of five government talks from the 2026 DoW Zero Trust Virtual Learning Exchange. It also has an audio overview, mind map, flashcards and quiz. Opening it needs a Google account. Start with its "START HERE" note: notebooklm.link.google/jaUFZqYbnxIe.
- **Another track's Week 5.** Reading how another sector does Zero Trust is the fastest way to see what is universal and what is local.

## DoW track

- **NSA "Advancing Zero Trust Maturity Throughout the ... Pillar" series (2023 to 2024).** One guide per pillar, and the best practical bridge between the activities and real controls. Read the User, Device and Network guides first.
- **NSA ZIG Phases Three and Four, when they publish.** The Advanced activities, in the same format as Discovery through Phase Two.
- **DoD Zero Trust Overlays (DoD CIO, June 2024).** Maps NIST SP 800-53 Rev. 5 controls to the Zero Trust activities. No longer posted on the DoW CIO site; the Sources section links an archived copy.
- **Zero Trust for Operational Technology Activities and Outcomes (DoW CIO).** The OT counterpart to the activity list, for anyone whose environment includes control systems.
- **Your component's own Zero Trust guidance,** as enterprise efforts (identity, endpoint, network) reach the environments you work in.

## Federal civilian track

- **CISA Microsegmentation, the technical guide, when it publishes.** CISA has announced a follow-on technical implementation guide.
- **The DoD activity list and NSA guidelines.** A finer-grained model of the same areas. Worth reading once your own terms are solid.

## Private sector track

- **The rest of SP 1800-35's example builds,** for the patterns your first build did not show.
- **NIST SP 800-207A,** if your applications run as cloud-native services.

## Talks to watch

Recorded talks that put a voice to the documents. All are free and public, with no sign-in. Watch your track's three before its Week 5. Half of these are also in the companion notebook, which holds transcripts of five government talks from the Exchange.

### CORE

- **John Kindervag: "Containment, ZT and the Security Graph: The Path to Anti-Fragility"** (DoW Zero Trust Virtual Learning Exchange, April 2026, 52 min). The person who coined the term Zero Trust, on designing outward from what you protect. Watch on WarU Media

### DoW TRACK

- **Dr. Shelly Kelly, NSA: "Zero Trust Implementation Guidelines (ZIGs)"** (DoW Zero Trust Virtual Learning Exchange, April 2026, 23 min). How the four ZIG documents fit together and how each role should use them. Pair it with the ZIG Primer. Watch on WarU Media
- **Randy Resnick, DoW Zero Trust Portfolio Management Office: centralized Zero Trust planning** (DefenseScoop, December 2025, 5 min). How the PfMO coordinates 40 components' Zero Trust implementation plans, now quarterly instead of annual. Watch on YouTube
- **David Voelker, Department of the Navy: "Zero Trust for Operational Technology"** (DoW Zero Trust Virtual Learning Exchange, April 2026, 24 min). The OT activities in practice, with the identity team and the cybersecurity service provider as partners. Watch on WarU Media

### FEDERAL CIVILIAN TRACK

- **CISA and DoD architects: "Understanding the CISA Maturity Model and DoD's Zero Trust Strategy"** (Cloud Security Alliance webcast, October 2023, 64 min). CISA's ZTMM authors and the DoD PfMO compare the two models side by side. Watch on YouTube
- **Sean Connelly: "Zero Trust as Global Policy: How Governments Are Adopting Zero Trust"** (DoW Zero Trust Virtual Learning Exchange, April 2026, 20 min). How governments, starting with the US federal model, are writing Zero Trust into policy. Watch on WarU Media
- **ATARC panel: "Mastering Zero Trust: Leveraging Network Visibility in Zero Trust Frameworks"** (December 2024, 60 min). Mostly federal practitioners on the visibility and analytics work that every other pillar depends on. Watch on YouTube

### PRIVATE SECTOR TRACK

- **Andy Ellis: "Leading to Zero Trust: Principles for a Smooth Journey"** (DoW Zero Trust Virtual Learning Exchange, April 2026, 23 min). The leadership and change side of a Zero Trust program. Watch on WarU Media
- **Jennifer Minella: "The Zero Trust Maturity Myth"** (DoW Zero Trust Virtual Learning Exchange, April 2026, 20 min). A useful counterweight to chasing maturity scores. Watch on WarU Media
- **Rich Mogull: "When AI Breaks Security: Why Zero Trust Is No Longer Optional"** (DoW Zero Trust Virtual Learning Exchange, April 2026, 33 min). Why AI raises the stakes for the basics. Watch on WarU Media

### AI AGENTS

- **Niki Aimable Niyikiza: "Capability-Based Authorization for AI Agents: Warrants That Survive Prompt Injection"** ([un]prompted 2026, March 2026, 29 min). Task-scoped permissions that can only narrow as work is handed on, so an injected prompt cannot widen what an agent may do. Watch on YouTube

- **Matt Maisel: "Hooking Coding Agents with the Cedar Policy Language"** ([un]prompted 2026, March 2026, 17 min). A policy engine outside the model checks every agent action: SP 800-207's decision point, applied to agents. Watch on YouTube

### Where the sources live

Checked 30 September 2026. Every link is in the Sources section.

- **NIST CSRC (csrc.nist.gov):** SP 800-207, 800-207A, 1800-35, CSF 2.0 and SP 800-171.
- **CISA (cisa.gov):** ZTMM 2.0 and the microsegmentation guidance.
- **OMB (whitehouse.gov):** M-22-09 and M-26-14.
- **Federal Register (federalregister.gov):** EO 14028 and EO 14347.
- **DoW CIO library (dowcio.war.gov, Library):** the Strategy, Reference Architecture, Capabilities and Activities, and the OT activities.
- **NSA (nsa.gov, media.defense.gov):** the ZIG series and the pillar guides.
- **Talks:** WarU Media (media.waru.edu) for the 2026 DoW Zero Trust Virtual Learning Exchange; YouTube for the rest.

# Sources

## Core

| SOURCE | PUBLISHER, DATE | LINK |
|---|---|---|
| Zero Trust Architecture, NIST SP 800-207 | NIST, Aug 2020 | https://csrc.nist.gov/pubs/sp/800/207/final |
| A Zero Trust Architecture Model for Access Control in Cloud-Native Applications in Multi-Cloud Environments, NIST SP 800-207A | NIST, Sep 2023 | https://csrc.nist.gov/pubs/sp/800/207/a/final |
| Zero Trust Maturity Model v2.0 | CISA, Apr 2023 | https://www.cisa.gov/sites/default/files/2023-04/zero_trust_maturity_model_v2_508.pdf |
| Zero Trust Maturity Model (landing page) | CISA | https://www.cisa.gov/resources-tools/resources/zero-trust-maturity-model |
| Zero Trust in the Age of AI (see-also; the author's companion NotebookLM notebook; opening it needs a Google account) | Ken Connell | https://notebooklm.link.google/jaUFZqYbnxIe |
| Agentic SecOps (see-also; the author's own companion project) | Ken Connell | https://kensden.github.io/lensatic/playbook/ |
| Zero Trust for AI Systems, v1.0 | Coalition for Secure AI (CoSAI, an OASIS Open Project), Sep 2026 | https://github.com/cosai-oasis/ws2-defenders/blob/main/zero-trust/Zero-Trust-for-AI-Systems.pdf |

## DoW

| SOURCE | PUBLISHER, DATE | LINK |
|---|---|---|
| EO 14347, Restoring the United States Department of War | White House, Sep 2025 | https://www.federalregister.gov/documents/2025/09/10/2025-17508/restoring-the-united-states-department-of-war |
| DoD Zero Trust Strategy | DoD CIO, Oct 2022 | https://dowcio.war.gov/Portals/0/Documents/Library/DoD-ZTStrategy.pdf |
| DoD Zero Trust Reference Architecture v2.0 | DISA and NSA for DoD CIO, Jul 2022 | https://dowcio.war.gov/Portals/0/Documents/Library/(U)ZT_RA_v2.0(U)_Sep22.pdf |
| DoD Zero Trust Capabilities and Activities (current activity list) | DoD CIO ZT PfMO, 18 Mar 2025 | https://dowcio.war.gov/Portals/0/Documents/Library/ZT-CapabilitiesActivities.pdf |
| Earlier activity list at the unhyphenated address (for the warning only) Archived copy (Wayback Machine, 7 Mar 2025); the original address returns 404. | DoD CIO, Jan 2023 | https://web.archive.org/web/20250307065129/https://dodcio.defense.gov/Portals/0/Documents/Library/ZTCapabilitiesActivities.pdf |
| DoD Zero Trust Overlays v1.1 Archived copy (Wayback Machine, 27 May 2025); no longer on the DoW CIO site, and the official addresses return 404. | DoD CIO, Jun 2024 | https://web.archive.org/web/20250527093843/https://dodcio.defense.gov/Portals/0/Documents/Library/ZeroTrustOverlays.pdf |
| Zero Trust for Operational Technology Activities and Outcomes | DoW CIO | https://dowcio.war.gov/Portals/0/Documents/Library/ZT-OperationalTechnologyActivitiesOutcomes_v2.pdf |
| DoW CIO Library (index) | DoW CIO | https://dowcio.war.gov/Library/ |

| SOURCE | PUBLISHER, DATE | LINK |
|---|---|---|
| ZIG Primer | NSA, 14 Jan 2026 | https://media.defense.gov/2026/Jan/08/2003852320/-1/-1/0/CTR_ZERO_TRUST_IMPLEMENTATION_GUIDELINE_PRIMER.PDF |
| ZIG Discovery Phase | NSA, 14 Jan 2026 | https://media.defense.gov/2026/Jan/08/2003852321/-1/-1/0/CTR_ZIG_DISCOVERY_PHASE.PDF |
| ZIG Phase One | NSA, 30 Jan 2026 | https://media.defense.gov/2026/Jan/30/2003868308/-1/-1/0/CTR_ZIG_PHASE_ONE.PDF |
| ZIG Phase Two | NSA, 30 Jan 2026 | https://media.defense.gov/2026/Jan/30/2003868302/-1/-1/0/CTR_ZIG_PHASE_TWO.PDF |
| NSA press release, Primer and Discovery Phase | NSA, 14 Jan 2026 | https://www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/4378980/nsa-releases-first-in-series-of-zero-trust-implementation-guidelines/ |
| NSA press release, Phase One and Two | NSA, 30 Jan 2026 | https://www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/4393480/nsa-releases-phase-one-and-phase-two-of-the-zero-trust-implementation-guidelines/ |
| Advancing Zero Trust Maturity Throughout the ... Pillar (seven guides)<br>The title links NSA's July 2024 release, which recaps all seven. | NSA, 2023 to 2024 | https://www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/3833594/nsas-final-zero-trust-pillar-report-outlines-how-to-achieve-faster-threat-respo/<br>User Pillar (Mar 2023; v1.1 Apr 2023)<br>https://media.defense.gov/2023/Mar/14/2003178390/-1/-1/0/CSI_Zero_Trust_User_Pillar_v1.1.PDF<br>Device Pillar (Oct 2023)<br>https://media.defense.gov/2023/Oct/19/2003323562/-1/-1/0/CSI-DEVICE-PILLAR-ZERO-TRUST.PDF<br>Application and Workload Pillar (May 2024)<br>https://media.defense.gov/2024/May/22/2003470825/-1/-1/0/CSI-APPLICATION-AND-WORKLOAD-PILLAR.PDF<br>Data Pillar (Apr 2024)<br>https://media.defense.gov/2024/Apr/09/2003434442/-1/-1/0/CSI_DATA_PILLAR_ZT.PDF<br>Network and Environment Pillar (Mar 2024)<br>https://media.defense.gov/2024/Mar/05/2003405462/-1/-1/0/CSI-ZERO-TRUST-NETWORK-ENVIRONMENT-PILLAR.PDF<br>Automation and Orchestration Pillar (Jul 2024)<br>https://media.defense.gov/2024/Jul/10/2003500250/-1/-1/0/CSI-ZT-AUTOMATION-ORCHESTRATION-PILLAR.PDF<br>Visibility and Analytics Pillar (May 2024)<br>https://media.defense.gov/2024/May/30/2003475230/-1/-1/0/CSI-VISIBILITY-AND-ANALYTICS-PILLAR.PDF |

## Federal civilian

| SOURCE | PUBLISHER, DATE | LINK |
|---|---|---|
| EO 14028, Improving the Nation's Cybersecurity | White House, May 2021 | https://www.federalregister.gov/documents/2021/05/17/2021-10460/improving-the-nations-cybersecurity |
| OMB M-22-09, Moving the U.S. Government Toward Zero Trust Cybersecurity Principles | OMB, Jan 2022 | https://www.whitehouse.gov/wp-content/uploads/2022/01/M-22-09.pdf |

| SOURCE | PUBLISHER, DATE | LINK |
|---|---|---|
| OMB M-26-14, Ensuring Effective and Efficient Agency Logging and Network Visibility to Defend Against Evolving Cyber Threats | OMB, May 2026 | https://www.whitehouse.gov/wp-content/uploads/2026/05/M-26-14-Ensuring-Effective-and-Efficient-Agency-Logging-and-Network-Visibility-to-Defend-Against-Evolving-Cyber-Threats.pdf |
| OMB memoranda (index) | OMB | https://www.whitehouse.gov/omb/information-resources/guidance/memoranda |
| Microsegmentation in Zero Trust, Part One: Introduction and Planning | CISA, Jul 2025 | https://www.cisa.gov/resources-tools/resources/microsegmentation-zero-trust-part-one-introduction-and-planning<br>PDF: https://www.cisa.gov/sites/default/files/2025-07/ZT-Microsegmentation-Guidance-Part-One_508c.pdf |
| Federal Zero Trust Data Security Guide<br>The official PDF on resources.data.gov. The guide's cio.gov page no longer loads. | Federal CISO Council and CDO Council, Oct 2024, rev. May 2025 | https://resources.data.gov/assets/documents/Zero-Trust-DataSecurityGuide_RevisedMay2025_CIO.govVersion.pdf |

## Private sector

| SOURCE | PUBLISHER, DATE | LINK |
|---|---|---|
| Microsegmentation in Zero Trust, Part One: Introduction and Planning | CISA, Jul 2025 | https://www.cisa.gov/resources-tools/resources/microsegmentation-zero-trust-part-one-introduction-and-planning<br>PDF: https://www.cisa.gov/sites/default/files/2025-07/ZT-Microsegmentation-Guidance-Part-One_508c.pdf |
| The NIST Cybersecurity Framework (CSF) 2.0, CSWP 29 | NIST, Feb 2024 | https://csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-csf-20/final |
| Implementing a Zero Trust Architecture, NIST SP 1800-35 | NIST NCCoE, Jun 2025 | https://csrc.nist.gov/pubs/sp/1800/35/final |
| Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations, NIST SP 800-171 Rev. 3 | NIST, May 2024 | https://csrc.nist.gov/pubs/sp/800/171/r3/final |
| Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations, NIST SP 800-171 Rev. 2<br>The CMMC program's Level 2 requirements are identical to Rev. 2 (32 CFR 170.14(c)(3)); NIST withdrew Rev. 2 when it published Rev. 3. Checked 29 September 2026. | NIST, Feb 2020, updated Jan 2021 | https://csrc.nist.gov/pubs/sp/800/171/r2/upd1/final |
| Cybersecurity Maturity Model Certification (CMMC) Program, 32 CFR Part 170 | DoD CIO, Oct 2024 | https://www.govinfo.gov/content/pkg/FR-2024-10-15/pdf/2024-22905.pdf |

## Talks

| SOURCE | PUBLISHER, DATE | LINK |
|---|---|---|
| John Kindervag: "Containment, ZT and the Security Graph: The Path to Anti-Fragility" | DoW Zero Trust Virtual Learning Exchange, Apr 2026 | https://media.waru.edu/playlist/dedicated/62925431/1_78sgkifi/1_u4dhitnh |
| Dr. Shelly Kelly, NSA: "Zero Trust Implementation Guidelines (ZIGs)" | DoW Zero Trust Virtual Learning Exchange, Apr 2026 | https://media.waru.edu/playlist/dedicated/62925431/1_78sgkifi/1_bzak7d09 |

| SOURCE | PUBLISHER, DATE | LINK |
|---|---|---|
| Randy Resnick, DoW Zero Trust Portfolio Management Office: "DOW's Randy Resnick on how centralized zero-trust planning prevents chaos" | DefenseScoop, Dec 2025 | https://www.youtube.com/watch?v=T4G4FHaS_6U |
| David Voelker, Department of the Navy: "Zero Trust for Operational Technology" | DoW Zero Trust Virtual Learning Exchange, Apr 2026 | https://media.waru.edu/playlist/dedicated/62925431/1_78sgkifi/1_sr95lihm |
| CISA and DoD panel: "Understanding the CISA Maturity Model and DoD's Zero Trust Strategy" | Cloud Security Alliance, Oct 2023 (on YouTube Mar 2026) | https://www.youtube.com/watch?v=wpAjYp0yiSs |
| Sean Connelly: "Zero Trust as Global Policy: How Governments Are Adopting Zero Trust" | DoW Zero Trust Virtual Learning Exchange, Apr 2026 | https://media.waru.edu/playlist/dedicated/62925431/1_og8bhh9i/1_l01174ak |
| ATARC webinar: "Mastering Zero Trust: Leveraging Network Visibility in Zero Trust Frameworks" | ATARC, Dec 2024 | https://www.youtube.com/watch?v=yoSKqpQhio8 |
| Andy Ellis: "Leading to Zero Trust: Principles for a Smooth Journey" | DoW Zero Trust Virtual Learning Exchange, Apr 2026 | https://media.waru.edu/playlist/dedicated/62925431/1_khqyas09/1_ywwwu11x |
| Jennifer Minella: "The Zero Trust Maturity Myth" | DoW Zero Trust Virtual Learning Exchange, Apr 2026 | https://media.waru.edu/playlist/dedicated/62925431/1_og8bhh9i/1_tacy9nke |
| Rich Mogull: "When AI Breaks Security: Why Zero Trust Is No Longer Optional" | DoW Zero Trust Virtual Learning Exchange, Apr 2026 | https://media.waru.edu/playlist/dedicated/62925431/1_og8bhh9i/1_8ebjco3g |
| Niki Aimable Niyikiza: "Capability-Based Authorization for AI Agents: Warrants That Survive Prompt Injection" | [un]prompted 2026, Mar 2026 | https://youtu.be/bw928cFShK4 |
| Matt Maisel: "Hooking Coding Agents with the Cedar Policy Language" | [un]prompted 2026, Mar 2026 | https://youtu.be/m6pzrqFJ6hE |

## About this edition

Public edition v2.8, 18 October 2026. v1.0 was written for DoW readers; v2.0 adds a shared core and tracks for federal civilian and private-sector readers. v2.1 changes only the license. v2.2 adds a list of talks to watch. v2.3 renames the guide and adds its icon. v2.4 briefly tries a different name, since retired. v2.5 tidies the layout and labels. v2.6 rebuilds the PDFs under the v2.3 name. v2.7 refocuses the exercises on learning and recasts Fluency 3. v2.8, 18 October 2026: joins Lensatic as a Field Guide. I adapted this guide from my own study notes, rebuilt from public sources only. I built it with Claude and Claude Code: Claude helped me research, verify and restructure it, and Claude Code built the page and PDFs. I reviewed every change, and I own the result, mistakes included.

A personal project: views are my own and do not represent any employer or government organization.

Copyright 2026 Ken Connell. All rights reserved. To ask about reuse, open an issue at github.com/KensDen/zero-trust-field-guide/issues. Built by Ken Connell with Claude and Claude Code.